

OFFENSIVE SECURITY OPERATIONS II

CTF 1 COMPETENCY EXAM

OPERATION IRON RAVEN

Black-Box Offensive Security Assessment Target OPFOR-01

Field	Entry
Course	Offensive Security Operations II (CIP-A105)
Student Name	Abubakar Mahmood Muhammad (Sadeeq)
Registration Number	C11/26/EHIT/17332
Submission Date	15/09/2026
Assessment Window	06 Sep 2026 00:00 WAT – 13 Sep 2026 23:59 WAT
Classification	TRAINING USE ONLY DO NOT REDISTRIBUTE

1. Executive Summary

This assessment evaluated the security posture of OPFOR-01, an Academy-issued Linux server hosting a WordPress installation, via an authorised black-box penetration test conducted entirely within an isolated laboratory network.

The assessment identified a confirmed information-disclosure vulnerability (directory listing) that led to the recovery of one mission artifact. The web application stack WordPress 4.8.7, Akismet 3.3.2, and the Twenty Seventeen 1.3 theme is significantly outdated (approx. 8 years past release), which independently elevates general risk even where a specific exploitable CVE could not be conclusively matched to the exact patch level observed.

A structured, evidence-based vulnerability research process was carried out against WordPress core and the Akismet plugin; the specific CVEs reviewed were determined not to apply to the exact version in use, as each had already been patched prior to 4.8.7. A controlled, ROE-compliant authentication-testing exercise was then conducted against the WordPress XML-RPC interface and the SSH service using a small, documented set of candidate credentials; no valid credentials were identified within the assessment window and time available.

No further privilege escalation or additional mission artifacts (flag1, flag2) were achieved within the assessment window. The assessment is assessed as partially complete: reconnaissance, enumeration, and vulnerability analysis were thorough and well-evidenced; initial access beyond the disclosed artifact was not achieved.

Summary Table

Metric	Value
Assessment Target	OPFOR-01 (raven.local / 192.168.72.130)
Assessment Date(s)	12–13 September 2026
Overall Risk Rating	Medium (outdated stack; confirmed low-severity information disclosure)
Confirmed Findings	4 (1 confirmed vulnerability, 3 documented analysis/control observations)
Highest Access Achieved	Unauthenticated no valid credentials obtained
Mission Artifacts Recovered	1 of up to 3 (flag3)

2. Scope and Rules of Engagement

Authorized Target

OPFOR-01, Academy-issued standalone Linux virtual machine (hostname raven.local, IP 192.168.72.130), isolated laboratory network only.

Authorized Attacker Workstation

Kali Linux VM (192.168.72.129), isolated segment VMware Workstation Pro, VMnet1 (Host-only), 192.168.72.0/24.

Boundaries Observed

- No scanning, exploitation, or interaction with any system outside OPFOR-01.
- Both VMs confined to VMnet1 (Host-only); no bridged networking or internet exposure of the target confirmed throughout.
- No destructive or denial-of-service testing performed.
- Authentication testing was scoped, rate-limited, and stopped at predefined thresholds (see Section 6).

3. Laboratory Architecture and Methodology

Lab Architecture

Kali attacker VM (192.168.72.129) and OPFOR-01 target VM (192.168.72.130) were both configured on VMware Workstation Pro's VMnet1 (Host-only network, 192.168.72.0/24, DHCP enabled). No bridged or NAT path existed between the lab segment and the internet; this was confirmed when WPScan's online database update failed to resolve an external hostname, verifying isolation.

Methodology

Testing followed the phased black-box methodology defined in the assessment brief:

- Phase 1 Reconnaissance / host discovery (nmap ping sweep)

- Phase 2 Attack-surface enumeration (nmap full-port/service scan, gobuster, whatweb, nikto)
- Phase 3 Vulnerability analysis and research (NVD, WPScan vulnerability database, vendor changelogs)
- Phase 4 Initial access attempt (controlled authentication testing)
- Phase 5 Post-exploitation (not reached no valid credentials obtained)
- Phase 6 Mission-artifact collection (flag3 recovered via misconfiguration)

Vulnerability Research Sources Consulted

- NVD (nvd.nist.gov)
- WPScan Vulnerability Database (wpscan.com/wordpress, wpscan.com/plugins)
- Akismet plugin changelog (wordpress.org/plugins/akismet)

4. Attack-Surface Summary / Asset Inventory

Component	Detected Version	Source / Evidence	Status
Operating System	Linux 3.x/4.x (fingerprint)	nmap -A OS detection	Aged kernel range
Web Server	Apache 2.4.10 (Debian)	nmap / whatweb / nikto	Outdated (2.x branch is EOL)
SSH	OpenSSH 6.7p1 (Debian)	nmap service scan	Outdated
CMS	WordPress 4.8.7	whatweb; wp-includes asset ?ver= query strings (independently cross-checked)	~8 years past release; specific reviewed CVEs already patched at this version
Plugin Akismet	3.3.2	readme.txt Stable tag	Outdated; no applicable CVE identified in time available

Theme	Twenty Seventeen 1.3	style.css header	Default WP theme, consistent with 4.7+ install
RPC	rpcbind (portmapper), port 111	Nmap	No NFS export found (showmount: Program not registered)
Site Identity	raven.local / "Raven Security"	HTTP Link header, page title	Matches target designation OPFOR-01

5. Confirmed Findings and Risk Ratings

Findings are numbered in order of discovery. Findings IR-002 through IR-004 document evidence-based analysis and testing that did not yield an exploitable vulnerability within the assessment window; these are retained per the brief's requirement to record failed hypotheses and the reasoning behind their elimination.

Finding IR-001 Directory Listing Enabled on wp-content/uploads/

Field	Entry
Finding ID	IR-001
Severity	Low–Medium
Affected Component	Apache 2.4.10 /wordpress/wp-content/uploads/
CWE	CWE-548 (Information Exposure Through Directory Listing)

Description

Apache directory indexing was enabled on the WordPress uploads directory, allowing unauthenticated traversal of the upload file tree without any linked reference from the site itself.

Evidence

Identified via Nikto scan ("Directory indexing found"), confirmed via direct HTTP request to /wordpress/wp-content/uploads/ and recursive mirroring of the /2018/ subtree using wget.

Attack Narrative

Nikto flagged directory indexing on multiple paths under the WordPress install. Manual traversal of /wp-content/uploads/ revealed a /2018/ subfolder, which in turn contained /11/, which contained a single file, flag3.png, not linked from any page on the site.

Security Impact

Allowed discovery and recovery of a mission artifact not otherwise discoverable. In a production context this class of misconfiguration commonly exposes sensitive uploaded files, drafts, or backups placed in the uploads directory without expectation of public listing.

Mission Objective Recovered

flag3{a0f568aa9de277887f37730d71520d9b} recovered from /wordpress/wp-content/uploads/2018/11/flag3.png (SHA256: 2479b9ab0c0763bf9bdc4c2fc36c701001a013a557a5a9f6beda44b024d9cc2e).

Remediation

Disable directory indexing (Options -Indexes) in the Apache virtual host configuration or via .htaccess.

Validation / Retest Guidance

Confirm that a direct request to /wp-content/uploads/ and subdirectories returns 403 Forbidden rather than a file listing.

Finding IR-002 WordPress Core / Plugin Version Review (No Exploitable CVE Confirmed)

Field	Entry
Finding ID	IR-002
Severity	Informational
Affected Component	WordPress core 4.8.7; Akismet 3.3.2

Description

WordPress core (4.8.7) and the bundled Akismet plugin (3.3.2) were version-fingerprinted and cross-referenced against the WPScan Vulnerability Database and NVD for known applicable CVEs.

Evidence and Reasoning

Two WordPress core candidates were evaluated in detail:

- WPVDB "WordPress <= 4.8.2 – \$wpdb->prepare() Weakness" (CVE-2017-16510): affected versions table lists 4.8, 4.8.1, and 4.8.2 as fixed in WordPress 4.8.3. Target version 4.8.7 post-dates this fix by several point releases ruled out. The entry itself also notes WordPress core is not directly vulnerable; the issue only affects plugins/themes misusing the API unsafely.
- WPVDB "WordPress 3.0-4.8.1 – Path Traversal in Unzipping": affected range ends at 4.8.1; target is 4.8.7 ruled out on the same basis (fixed prior to the installed version).
- Akismet 3.3.2: the official plugin changelog only documents versions 5.0 and later; no changelog entry or WPVDB record could be matched to 3.3.2 specifically within the assessment window. Not confirmed either applicable or inapplicable flagged as an area for further research beyond the time available.

Conclusion

No exploitable, version-specific CVE was conclusively matched to the exact core or plugin versions running on this target within the assessment window. This does not rule out an unpublished or unresearched issue; it reflects the limits of the research conducted in the time available. General risk from running an approximately 8-year-old, unsupported release remains valid and is reflected in the remediation roadmap.

Remediation

Upgrade WordPress core and all plugins to currently supported versions regardless of whether a specific CVE was matched, given the extended period without vendor security support.

Finding IR-003 XML-RPC Authentication Surface (Controlled Test No Valid Credentials Found)

Field	Entry
Finding ID	IR-003
Severity	Low / Informational
Affected Component	/wordpress/xmlrpc.php
CWE	CWE-287 (Improper Authentication) surface exposure only

Description

The WordPress XML-RPC endpoint was confirmed live and, via `system.listMethods`, was found to expose a full method set including `wp.getUsersBlogs` (requires username/password) and `system.multicall` (permits batched calls). Combined with a username (michael) disclosed separately via the WP REST API (`/rest_route=/wp/v2/users`), this constitutes a viable authentication-testing surface.

Evidence

`system.listMethods` response enumerated ~40 methods including authentication-dependent and content-management calls. A controlled authentication test was conducted using `wp.getUsersBlogs` with username michael against four candidate passwords (Michael12456, raven123, Raven2018, security1), each derived from the username and the site's own "Raven Security" branding. All four attempts returned a generic XML-RPC fault (code 403, "Incorrect username or password.").

Security Observation

The fault message does not distinguish an invalid username from an invalid password, which is a positive control against username enumeration via this specific endpoint (noting the username was already obtained through a separate channel the REST API independent of this control).

Test Discipline Applied

Attempts were manually paced (~4–5 seconds apart), limited to four candidates chosen with documented rationale, and logged with timestamps. Testing was stopped short of exhausting a wordlist given time constraints and to remain within a conservative, non-disruptive attempt volume.

Remediation

Disable XML-RPC entirely if not required by the site (common hardening recommendation for older WordPress installs), or restrict it via IP allowlisting / a security plugin; enforce strong password policy and consider rate-limiting/lockout at the application layer in addition to the generic fault message already in place.

Finding IR-004 SSH Authentication Behavior (Controlled Test No Valid Credentials Found)

Field	Entry
Finding ID	IR-004
Severity	Informational
Affected Component	OpenSSH 6.7p1 (Debian), port 22

Description

The same four candidate passwords used against XML-RPC were tested manually against the michael account via interactive SSH, to check for credential reuse across services.

Evidence

All attempts returned "Permission denied, please try again." In one session, the SSH connection was terminated by the server after two consecutive failed attempts ("Connection closed by 192.168.72.130 port 22"); in a subsequent session, four attempts were permitted before the operator paused testing. This inconsistency was observed but not further investigated within the assessment window.

Security Observation

The connection-drop behavior observed in one session is consistent with an SSH MaxAuthTries-style control, which provides some resistance to rapid credential guessing within a single connection (though does not prevent reconnection and further attempts).

Remediation

Enforce key-based authentication and disable password authentication for SSH where feasible; if password authentication is required, pair MaxAuthTries with fail2ban or an equivalent connection-level lockout across reconnection attempts.

6. Initial-Access Narrative

Initial access was not achieved within the assessment window. The following controlled, documented process was followed:

- A username (michael) was obtained via the unauthenticated WordPress REST API endpoint `/?rest_route=/wp/v2/users`.
- A test plan was defined in advance of any authentication attempt, including: candidate source (self-derived, documented rationale username- and site-theme-based patterns), a maximum attempt count, a minimum delay between attempts (~4–5 seconds), and explicit stop conditions (successful authentication, account lockout, HTTP 429/rate-limit response, application instability, or reaching the attempt cap).
- Four candidates were tested against the WordPress XML-RPC `wp.getUsersBlogs` method; all failed with a generic authentication fault.
- The same four candidates were tested against SSH for the same account, to check for credential reuse; all failed.
- Other candidate entry points were reviewed and ruled out: exposed backup/config files (`wp-config.php.bak`, `wp-config.php~` both 404), the site's RSS feed (empty, default install), the default homepage content (stock "Hello world!" post, no custom theme words), and account self-registration (explicitly disabled).

Given the assessment window, testing was stopped at this point per the predefined test plan rather than expanding the candidate list or attempt volume further, consistent with the Rules of Engagement's requirement to avoid uncontrolled or open-ended guessing.

7. Post-Exploitation and Privilege-Escalation Narrative

Not reached. No valid credentials or foothold were obtained during the assessment window, so post-exploitation enumeration and privilege escalation could not be attempted against the live target. Had access been obtained, planned next steps would have included standard local enumeration (sudo -l, SUID binaries, cron jobs, writable service files, credential files) consistent with the brief's Phase 5 guidance.

8. Mission Objectives and Proof of Completion

Objective / Flag	Access Level Required	Value	Evidence Ref.
flag3	Unauthenticated (misconfiguration)	a0f568aa9de277887f37730d71520d9b	Finding IR-001; SHA256 2479b9ab0c...9cc2e
flag2	Not recovered within assessment window	—	—
flag1	Not recovered within assessment window	—	—

9. Risk Register

ID	Finding	Severity	Likelihood	Impact	Remediation Priority
IR-001	Directory listing on uploads/	Low-Med	High	Low-Med	High
IR-002	Outdated WP core/plugin (no confirmed CVE)	Informational	N/A	N/A	Medium
IR-003	XML-RPC authentication surface exposed	Low	Medium	Medium	Medium
IR-004	SSH password auth surface exposed	Informational	Low-Med	Medium	Low

10. Remediation Roadmap

Priority 1 Immediate

- Disable Apache directory indexing (Options -Indexes) across the WordPress install.
- Upgrade WordPress core and all plugins to currently supported versions.

Priority 2 Short Term

- Disable XML-RPC if not required, or restrict access and enforce rate-limiting/lockout.
- Move SSH to key-based authentication only; if password auth is retained, pair with fail2ban or equivalent.
- Enforce a strong password policy for all WordPress and system accounts.

Priority 3 Strategic / Hardening

- Add missing security headers (X-Frame-Options, X-Content-Type-Options) identified by Nikto.
- Reduce information disclosure (readme.html version leakage, server banners).
- Establish a recurring patch-management cadence for CMS core and plugins.

11. Conclusion and Lessons Learned

Conclusion

OPFOR-01 presents a moderately outdated web application stack with at least one confirmed, low-severity information-disclosure vulnerability that yielded a mission artifact. No exploitable code-level vulnerability was conclusively matched to the exact software versions in use within the time available, and controlled authentication testing against two services did not yield valid credentials. The system should not be considered hardened; given its age and the unresolved authentication surface, it should remain restricted to isolated/lab use pending the remediation items above.

Lessons Learned

Failed / Discarded Hypotheses

- NFS export via rpcbind ruled out; showmount returned "Program not registered".
- WordPress core CVE (CVE-2017-16510, \$wpdb->prepare weakness) ruled out; fixed in 4.8.3, target is 4.8.7.
- WordPress core path traversal in unzipping ruled out; fixed range ends before 4.8.7.
- Exposed backup/config files (wp-config.php.bak/~) ruled out; both returned 404.
- RSS feed and default homepage content as a source of theme-specific credential hints ruled out; default install content only.
- Self-registration as an access path ruled out; explicitly disabled by the application.

Successful Reasoning

Systematic elimination of CVE candidates by cross-checking exact "fixed in" version numbers against the confirmed installed version (rather than relying on CVSS severity alone) correctly avoided pursuing two dead-end, already-patched issues. Directory-indexing discovery via Nikto, followed by manual/recursive traversal, was an effective and low-noise way to locate the one artifact that was recoverable without authentication.

Technical Gaps / Improvements for Next Operation

- Akismet 3.3.2 was never conclusively checked against an applicable CVE within the time available with more time, checking the plugin's SVN changelog.txt directly (rather than the current plugin page, which only lists recent versions) would be the next step.
- A larger, still-controlled candidate password list informed by more thorough content review earlier in the assessment may have improved the odds of the authentication tests succeeding.
- Time management: a firmer, earlier cut-off between vulnerability research and hands-on testing would have preserved more time for post-exploitation had access been obtained.

12. Appendices

Appendix A Operator Activity Log

Date/Time (WAT)	Phase	Action / Purpose	Result	Evidence Ref.
12 Sep 2026	Phase 0	Deploy OPFOR-01 in VMware Workstation Pro; set adapter to Host-only (VMnet1)	Both VMs confirmed on VMnet1 / 192.168.72.0/24	Screenshots of VM settings
12 Sep 2026	Phase 1	nmap -sn 192.168.72.0/24 (host discovery)	Target identified: 192.168.72.130 (MAC 00:0C:29:27:44:5E)	Screenshots of nmap sweep
12 Sep 2026	Phase 2	nmap -A -p- 192.168.72.130 (full port/service scan)	Ports open: 22 (SSH), 80 (HTTP), 111 (rpcbind), 58922 (status)	Screenshots of nmap -A
12 Sep 2026	Phase 2	gobuster dir (site root)	Found /wordpress/ among other default Apache paths	Screenshots of gobuster
12 Sep 2026	Phase 2	showmount -e 192.168.72.130	"RPC: Program not registered" no NFS export	Screenshots
12 Sep 2026	Phase 2	whatweb on /wordpress/	WordPress 4.8.7 confirmed, jQuery 1.12.4, title "Raven Security"	Screenshots
12 Sep 2026	Phase 2	nikto -h 192.168.72.130	Directory indexing found on /wp-content/uploads/ and others; Akismet readme found	Screenshots of nikto output

12 Sep 2026	Phase 2	wget recursive mirror of /wp-content/uploads/2018/	Recovered flag3.png (10.17 KB)	Screenshots; file saved locally
12 Sep 2026	Phase 6	eog flag3.png (manual view)	Image displays flag3 {a0f568aa9de277887f37730d71520d9b}	Screenshots
12 Sep 2026	Phase 2	curl REST API /?rest_route=/wp/v2/users	Username disclosed: michael	Screenshots
12 Sep 2026	Phase 2	curl xmlrpc.php system.listMethods	~40 methods enumerated incl. wp.getUsersBlogs, system.multicall	Screenshots
13 Sep 2026	Phase 3	WPScan / NVD manual review of WordPress core CVEs	Two candidate CVEs reviewed and ruled out (fixed pre-4.8.7)	Documents provided in session
13 Sep 2026	Phase 3	Akismet changelog review	No entry found covering 3.3.2 (changelog starts at 5.0)	Document provided in session
13 Sep 2026	Phase 4	Attempt 001 wp.getUsersBlogs, michael / Michael12456	Fault 403 Incorrect username or password	Screenshots
13 Sep 2026	Phase 4	Attempts 002–004 wp.getUsersBlogs, candidates raven123 /	All fault 403	Screenshots hot runner.sh output

		Raven2018 / security1		
13 Sep 2026	Phase 4	SSH michael@192.168.72.130 4 candidate passwords tested across two sessions	All "Permission denied"; one session closed after 2 attempts	Screenshots
13 Sep 2026	Phase 2/4	curl wp-config.php.bak / wp-config.php~	Both 404 no backup exposure	Screenshots
13 Sep 2026	Phase 2/4	curl /?feed=rss2; manual homepage review; wp-login.php?action=register	Default install content only; registration disabled	Screenshots
13 Sep 2026	Phase 7	sha256sum flag3.png	2479b9ab0c0763bf9bdc4c2fc36c701001a013a557a5a9f6beda44b024d9cc2e	Terminal output

Appendix B Evidence Screenshots (Phase 1–2: Recon & Enumeration)

```
(kali㉿kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:02:04:86 brd ff:ff:ff:ff:ff:ff
    inet 192.168.72.129/24 brd 192.168.72.255 scope global dynamic noprefixroute eth0
        valid_lft 1412sec preferred_lft 1412sec
    inet6 fe80::1ea9:fe2d:341:3ad6/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 4e:86:a6:59:3a:4f brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(kali㉿kali)-[~]
$
```

Fig. B1 Kali attacker interface configuration (eth0, 192.168.72.129) confirming isolated-network membership.

```
(kali㉿kali)-[~]
$ nmap -sn 192.168.72.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-12 07:15 EDT
Nmap scan report for 192.168.72.1
Host is up (0.048s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.72.254
Host is up (0.00061s latency).
MAC Address: 00:50:56:E6:14:E2 (VMware)
Nmap scan report for 192.168.72.129
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 29.79 seconds

(kali㉿kali)-[~]
$
```

Fig. B2 Initial nmap -sn host-discovery sweep of 192.168.72.0/24 (target not yet responding to ICMP).

```

kali@kali: ~
Session Actions Edit View Help

inet 192.168.72.129/24 brd 192.168.72.255 scope global dynamic noprefixroute eth0
    valid_lft 1722sec preferred_lft 1722sec
inet6 fe80::1ea9:fe2d:341:3ad6/64 scope link noprefixroute
    valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group
default
    link/ether 32:f9:7a:3a:ce:ff brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ nmap -sn 192.168.72.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-12 09:34 EDT
Nmap scan report for 192.168.72.1
Host is up (0.028s latency).
MAC Address: 00:50:56:C0:00:01 (VMware)
Nmap scan report for 192.168.72.130
Host is up (0.0021s latency).
MAC Address: 00:0C:29:27:44:5E (VMware)
Nmap scan report for 192.168.72.254
Host is up (0.0025s latency).
MAC Address: 00:50:56:E6:14:E2 (VMware)
Nmap scan report for 192.168.72.129
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 28.44 seconds

(kali@kali)-[~]
$

```

Fig. B3 Repeat nmap -sn sweep; OPFOR-01 identified at 192.168.72.130 (MAC 00:0C:29:27:44:5E).

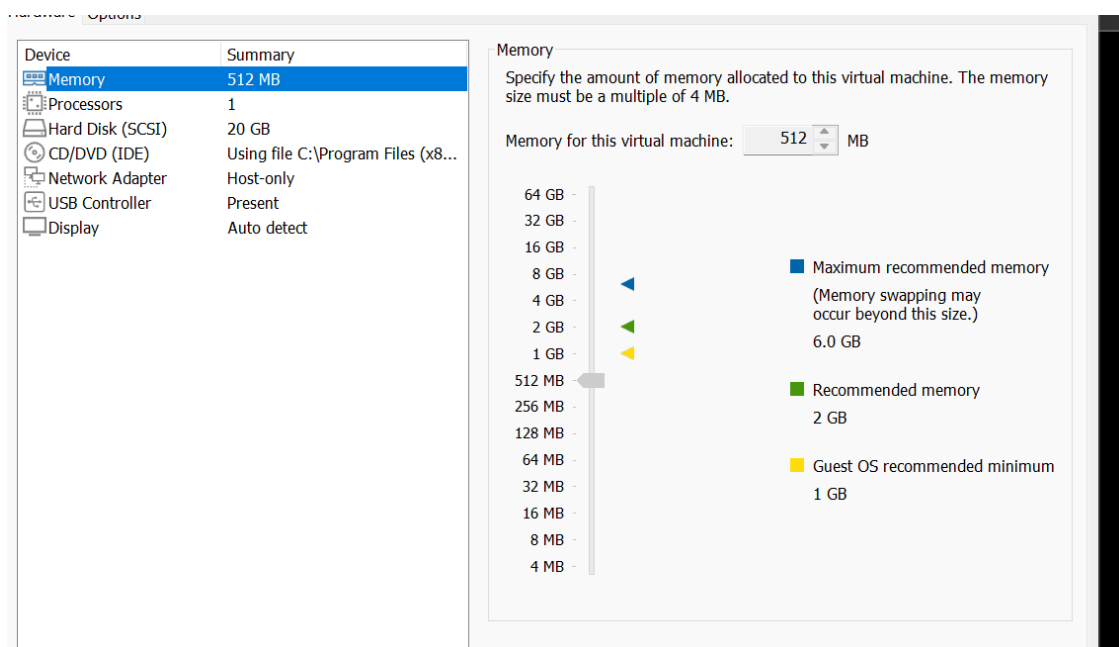


Fig. B4 OPFOR-01 (Raven2) VM hardware configuration confirming Host-only network adapter.

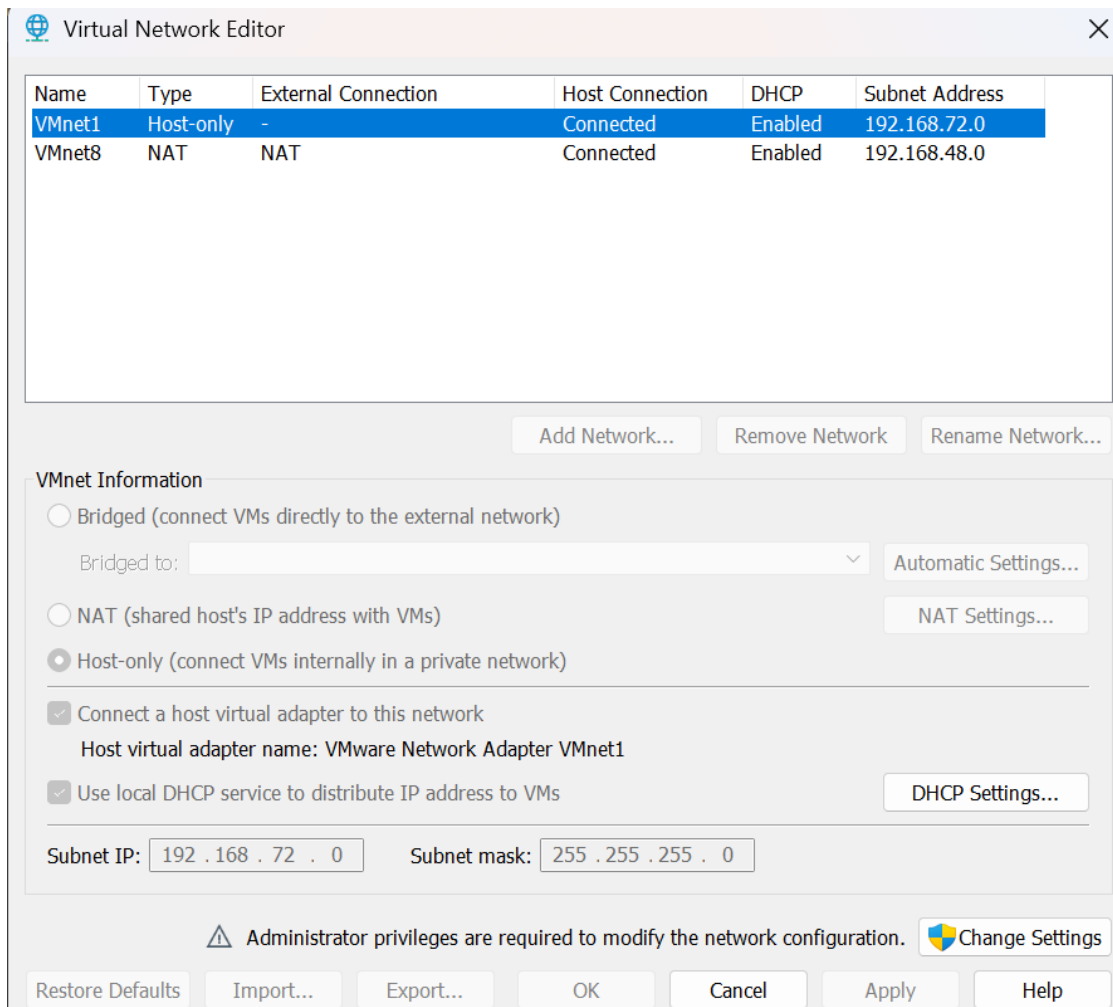


Fig. B5 VMware Virtual Network Editor confirming VMnet1 (Host-only, 192.168.72.0/24) as the shared isolated segment for both VMs.

```

Session Actions Edit View Help
(kali@kali)-[~]
$ nmap -A -p- 192.168.72.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-12 09:38 EDT
Nmap scan report for 192.168.72.130
Host is up (0.0083s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)
|_ ssh-hostkey:
|   1024 26:81:c1:f3:5e:01:ef:93:49:3d:91:1e:ae:8b:3c:fc (DSA)
|   2048 31:58:01:19:4d:a2:80:a6:b9:0d:40:98:1c:97:aa:53 (RSA)
|   256 1f:77:31:19:de:b0:e1:6d:ca:77:07:76:84:d3:a9:a0 (ECDSA)
|_  256 0e:85:71:a8:a2:c3:08:69:9c:91:c0:3f:84:18:df:ae (ED25519)
80/tcp    open  http      Apache httpd 2.4.10 ((Debian))
|_ http-server-header: Apache/2.4.10 (Debian)
|_ http-title: Raven Security
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4      111/tcp     rpcbind
|   100000  2,3,4      111/udp     rpcbind
|   100000  3,4        111/tcp6    rpcbind
|   100000  3,4        111/udp6    rpcbind
|   100024  1          37205/udp   status
|   100024  1          44975/udp6  status
|   100024  1          55285/tcp6  status
|_  100024  1          58922/tcp   status
58922/tcp open  status  1 (RPC #100024)
MAC Address: 00:0C:29:27:44:5E (VMware)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   8.34 ms  192.168.72.130

OS and Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.81 seconds

```

Fig. B6 Full TCP port/service scan (*nmap -A -p-*) of 192.168.72.130: ports 22 (SSH), 80 (HTTP), 111 (rpcbind), 58922 (status) open.

```

(kali@kali)-[~]
$ gobuster dir -u http://192.168.72.130 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://192.168.72.130
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.8
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

/.hta                (Status: 403) [Size: 293]
/.htaccess           (Status: 403) [Size: 298]
/.htpasswd           (Status: 403) [Size: 298]
/css                 (Status: 301) [Size: 314] [→ http://192.168.72.130/css/]
/fonts               (Status: 301) [Size: 316] [→ http://192.168.72.130/fonts/]
/img                 (Status: 301) [Size: 314] [→ http://192.168.72.130/img/]
/index.html          (Status: 200) [Size: 16819]
/js                  (Status: 301) [Size: 313] [→ http://192.168.72.130/js/]
/manual              (Status: 301) [Size: 317] [→ http://192.168.72.130/manual/]
/server-status       (Status: 403) [Size: 302]
/vendor              (Status: 301) [Size: 317] [→ http://192.168.72.130/vendor/]
/wordpress           (Status: 301) [Size: 320] [→ http://192.168.72.130/wordpress/]
Progress: 4613 / 4613 (100.00%)

Finished

```

Fig. B7 gobuster directory enumeration of the web root, identifying /wordpress/.

```
(kali㉿kali)-[~]  
$ showmount -e 192.168.72.130  
clnt_create: RPC: Program not registered  
  
(kali㉿kali)-[~]  
$
```

Fig. B8 showmount -e result: no NFS export registered despite rpcbind being open (ruled out as an entry vector).

```
(kali㉿kali)-[~]  
$ whatweb http://192.168.72.130/wordpress/  
http://192.168.72.130/wordpress/ [200 OK] Apache[2.4.10], Country[RESERVED][ZZ], HTML5, HTTPServer[Debian Linux][Apache/2.4.10 (Debian)], IP[192.168.72.130], JQuery[1.12.4], MetaGenerator[WordPress 4.8.7], PoweredBy[WordPress,WordPress,], Script[text/javascript], Title[Raven Security 6#8211; Just another WordPress site], UncommonHeaders[link], WordPress[4.8.7]  
  
(kali㉿kali)-[~]  
$
```

Fig. B9 whatweb fingerprint confirming WordPress 4.8.7, jQuery 1.12.4, and site title "Raven Security".

Appendix B (cont.) Web Application Enumeration

```
(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/wp-content/themes/twentyseventeen/style.css | head -20
/*
Theme Name: Twenty Seventeen
Theme URI: https://wordpress.org/themes/twentyseventeen/
Author: the WordPress team
Author URI: https://wordpress.org/
Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a focus on business
sites, it features multiple sections on the front page as well as widgets, navigation and social menus, a logo, and more. Person
lize its asymmetrical grid with a custom color scheme and showcase your multimedia content with post formats. Our default theme
or 2017 works great in many languages, for any abilities, and on any device.
Version: 1.3
License: GNU General Public License v2 or later
License URI: http://www.gnu.org/licenses/gpl-2.0.html
Text Domain: twentyseventeen
Tags: one-column, two-columns, right-sidebar, flexible-header, accessibility-ready, custom-colors, custom-header, custom-menu, c
ustom-logo, editor-style, featured-images, footer-widgets, post-formats, rtl-language-support, sticky-post, theme-options, thread
d-comments, translation-ready

This theme, like WordPress, is licensed under the GPL.
Use it to make something cool, have fun, and share what you've learned with others.
*/

/*
____
>>> TABLE OF CONTENTS:
____
1.0 Normalize
```

Fig. B10 Direct retrieval of the active theme's style.css confirming Twenty Seventeen v1.3.

```
____
/*
____
>>> TABLE OF CONTENTS:
____
1.0 Normalize

(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/xmlrpc.php
XML-RPC server accepts POST requests only.

(kali@kali)-[~]
$
```

Fig. B11 XML-RPC endpoint reachability check (xmlrpc.php) confirming the interface is live.

```
(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/ | grep -i "wp-content"
<link rel='stylesheet' id='twentyseventeen-style-css' href='http://raven.local/wordpress/wp-content/themes/twentyseventeen/style
.css?ver=4.8.7' type='text/css' media='all' />
<link rel='stylesheet' id='twentyseventeen-ie8-css' href='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/
css/ie8.css?ver=1.0' type='text/css' media='all' />
<script type='text/javascript' src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/html5.js?ver=3.7.3'>
</script>
<div id='wp-custom-header' class='wp-custom-header'><img src='http://raven.local/wordpress/wp-content/the
mes/twentyseventeen/assets/images/header.jpg' width='2000' height='1200' alt='Raven Security' /></div>
<script type='text/javascript' src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/skip-link-focus-fix.
js?ver=1.0'></script>
<script type='text/javascript' src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/global.js?ver=1.0'>
</script>
<script type='text/javascript' src='http://raven.local/wordpress/wp-content/themes/twentyseventeen/assets/js/jquery.scrollTo.js?v
er=2.1.2'></script>

(kali@kali)-[~]
$
```

Fig. B12 Homepage asset references (curl | grep "wp-content") independently corroborating WordPress core version 4.8.7 via asset ?ver= query strings.

```

└─$ nikto -h http://192.168.72.130
- Nikto v2.5.0

+ Target IP: 192.168.72.130
+ Target Hostname: 192.168.72.130
+ Target Port: 80
+ Start Time: 2026-09-12 10:28:21 (GMT-4)

+ Server: Apache/2.4.10 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Server may leak inodes via ETags, header found with file /, inode: 41b3, size: 5734482bdc00, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /css/: Directory indexing found.
+ /css/: This might be interesting.
+ /img/: Directory indexing found.
+ /img/: This might be interesting.
+ /manual/: Web server manual found.
+ /manual/images/: Directory indexing found.
+ /.DS_Store: Apache on Mac OSX will serve the .DS_Store file, which contains sensitive information. Configure Apache to ignore this file or upgrade to a newer version. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-1446
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /wordpress/wp-content/plugins/akismet/readme.txt: The WordPress Akismet plugin 'Tested up to' version usually matches the WordPress version.
+ /wordpress/wp-links-opml.php: This WordPress script reveals the installed version.
+ /wordpress/: Drupal link header found with value: <http://raven.local/wordpress/index.php/wp-json/>; rel="https://api.w.org/". See: https://www.drupal.org/
+ /wordpress/: A Wordpress installation was found.
+ /wordpress/wp-login.php?action=register: Cookie wordpress_test_cookie created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /wordpress/wp-content/uploads/: Directory indexing found.
+ /wordpress/wp-content/uploads/: Wordpress uploads directory is browsable. This may reveal sensitive information.
+ /wordpress/wp-login.php: Wordpress login found.
+ 8103 requests: 0 error(s) and 21 item(s) reported on remote host
+ End Time: 2026-09-12 10:28:46 (GMT-4) (25 seconds)

+ 1 host(s) tested

└─(kali@kali)-[~]

```

Fig. B13 Full Nikto scan output: directory indexing flagged on multiple paths, including /wp-content/uploads/.

```

└─(kali@kali)-[~]
└─$ echo "192.168.72.130 raven.local" | sudo tee -a /etc/hosts
[sudo] password for kali:
192.168.72.130 raven.local
└─(kali@kali)-[~]
└─$

```

Fig. B14 Local /etc/hosts entry added for raven.local to match the server's internal hostname.

```

(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/wp-content/uploads/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /wordpress/wp-content/uploads/</title>
</head>
<body>
<h1>Index of /wordpress/wp-content/uploads/</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href="/wordpress/wp-content/">Parent Directory</a></td><td><td align="right">-</td><td><td align="right"></td></tr>
<tr><td valign="top"></td><td><a href="2018/">2018/</a></td><td align="right">2018-11-09 08:26</td><td align="right">-</td><td><td align="right"></td></tr>
<tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.4.10 (Debian) Server at 192.168.72.130 Port 80</address>
</body></html>

(kali@kali)-[~]
$

```

Fig. B15 Confirmed directory listing on /wp-content/uploads/, revealing an unlinked /2018/ subfolder (Finding IR-001).

```

(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/wp-content/uploads/2018/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /wordpress/wp-content/uploads/2018/</title>
</head>
<body>
<h1>Index of /wordpress/wp-content/uploads/2018/</h1>
<table>
<tr><th valign="top"></th><th><a href="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></tr>
<tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"></td><td><a href="/wordpress/wp-content/uploads/">Parent Directory</a></td><td><td align="right">-</td><td><td align="right"></td></tr>
<tr><td valign="top"></td><td><a href="11/">11/</a></td><td align="right">2018-11-09 08:26</td><td align="right">-</td><td><td align="right"></td></tr>
<tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.4.10 (Debian) Server at 192.168.72.130 Port 80</address>
</body></html>

(kali@kali)-[~]
$

```

Fig. B16 Traversal into /uploads/2018/, revealing the /11/ subfolder.

```

2018/11/index.html?C=M;O=A.tmp 100%[=====] 1.01K --.-KB/s in 0s
2026-09-12 10:33:25 (47.3 MB/s) - '2018/11/index.html?C=M;O=A.tmp' saved [1035/1035]
Removing 2018/11/index.html?C=M;O=A.tmp since it should be rejected.
--2026-09-12 10:33:25-- http://192.168.72.130/wordpress/wp-content/uploads/2018/11/?C=S;O=A
Reusing existing connection to 192.168.72.130:80.
HTTP request sent, awaiting response... 200 OK
Length: 1035 (1.0K) [text/html]
Saving to: '2018/11/index.html?C=S;O=A.tmp'
2018/11/index.html?C=S;O=A.tmp 100%[=====] 1.01K --.-KB/s in 0s
2026-09-12 10:33:25 (55.9 MB/s) - '2018/11/index.html?C=S;O=A.tmp' saved [1035/1035]
Removing 2018/11/index.html?C=S;O=A.tmp since it should be rejected.
--2026-09-12 10:33:25-- http://192.168.72.130/wordpress/wp-content/uploads/2018/11/?C=D;O=A
Reusing existing connection to 192.168.72.130:80.
HTTP request sent, awaiting response... 200 OK
Length: 1035 (1.0K) [text/html]
Saving to: '2018/11/index.html?C=D;O=A.tmp'
2018/11/index.html?C=D;O=A.tmp 100%[=====] 1.01K --.-KB/s in 0s
2026-09-12 10:33:25 (56.4 MB/s) - '2018/11/index.html?C=D;O=A.tmp' saved [1035/1035]
Removing 2018/11/index.html?C=D;O=A.tmp since it should be rejected.
--2026-09-12 10:33:25-- http://192.168.72.130/wordpress/wp-content/uploads/2018/11/flag3.png
Reusing existing connection to 192.168.72.130:80.
HTTP request sent, awaiting response... 200 OK
Length: 10411 (10K) [image/png]
Saving to: '2018/11/flag3.png'
2018/11/flag3.png 100%[=====] 10.17K --.-KB/s in 0s
2026-09-12 10:33:25 (264 MB/s) - '2018/11/flag3.png' saved [10411/10411]
--2026-09-12 10:33:25-- http://192.168.72.130/wordpress/wp-content/uploads/2018/11/?C=N;O=A
Reusing existing connection to 192.168.72.130:80.
HTTP request sent, awaiting response... 200 OK
Length: 1035 (1.0K) [text/html]
Saving to: '2018/11/index.html?C=N;O=A.tmp'

```

Fig. B17 Recursive mirror (wget) of the uploads tree, showing flag3.png (10.17 KB) successfully retrieved.

flag3{a0f568aa9de277887f37730d71520d9b}

Fig. B18 Contents of the recovered artifact: flag3{a0f568aa9de277887f37730d71520d9b}.

```

(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/plugins/akismet/readme.txt | grep -i "stable tag"
Stable tag: 3.3.2
(kali@kali)-[~]

```

Fig. B19 Akismet plugin readme.txt confirming Stable tag: 3.3.2.

Appendix C Evidence Screenshots (Phase 3–4: Analysis & Authentication Testing)

```
(kali㉿kali)-[~]
└─$ curl -s http://192.168.72.130/wordpress/?rest_route=/wp/v2/users
[{"id":1,"name":"michael","url":"","description":"","link":"http://\raven.local\wordpress\index.php\author\michael\/","slug":"michael","avatar_urls":{"24":"http://\0.gravatar.com\avatar\604e47508b7ee36deef09f80e394efa?s=24&mm6r=g","48":"http://\0.gravatar.com\avatar\604e47508b7ee36deef09f80e394efa?s=48&mm6r=g","96":"http://\0.gravatar.com\avatar\604e47508b7ee36deef09f80e394efa?s=96&mm6r=g"},"meta":{"_links":{"self":{"href":"http://\raven.local\wordpress\index.php\wp-json\wp/v2/users\/1"}},"collection":{"href":"http://\raven.local\wordpress\index.php\wp-json\wp/v2/users"}}}]

(kali㉿kali)-[~]
└─$
```

Fig. C1 Unauthenticated WordPress REST API request (/wp/v2/users) disclosing a valid username: michael.

```
(kali㉿kali)-[~]
└─$ curl -v http://192.168.72.130/wordpress/wp-content/plugins/hello.php
* Trying 192.168.72.130:80...
* Established connection to 192.168.72.130 (192.168.72.130 port 80) from 192.168.72.129 port 58894
* using HTTP/1.x
> GET /wordpress/wp-content/plugins/hello.php HTTP/1.1
> Host: 192.168.72.130
> User-Agent: curl/8.20.0
> Accept: */*
>
* Request completely sent off
* HTTP 1.0, assume close after body
< HTTP/1.0 500 Internal Server Error
< Date: Sat, 12 Sep 2026 15:11:01 GMT
< Server: Apache/2.4.10 (Debian)
< Content-Length: 0
< Connection: close
< Content-Type: text/html; charset=UTF-8
<
* shutting down connection #0

(kali㉿kali)-[~]
└─$ curl -s http://192.168.72.130/wordpress/xmlrpc.php -d '<?xml version="1.0"?><methodCall><methodName>system.listMethods</methodName><params></params></methodCall>'
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <params>
    <param>
      <value>
        <array><data>
          <value><string>system.multicall</string></value>
          <value><string>system.listMethods</string></value>
          <value><string>system.getCapabilities</string></value>
          <value><string>demo.addTwoNumbers</string></value>
          <value><string>demo.sayHello</string></value>
          <value><string>pingback.extensions.getPingbacks</string></value>
          <value><string>pingback.ping</string></value>
          <value><string>mt.publishPost</string></value>
          <value><string>mt.getTrackbackPings</string></value>
          <value><string>mt.supportedTextFilters</string></value>
        </data>
      </value>
    </param>
  </params>
</methodResponse>
```

Fig. C2 XML-RPC system.listMethods response (part 1) confirming wp.getUsersBlogs and system.multicall are exposed.

```
kali@kali: ~  
Session Actions Edit View Help  
<value><string>wp.deleteComment</string></value>  
<value><string>wp.getComments</string></value>  
<value><string>wp.getComment</string></value>  
<value><string>wp.setOptions</string></value>  
<value><string>wp.getOptions</string></value>  
<value><string>wp.getPageTemplates</string></value>  
<value><string>wp.getPageStatusList</string></value>  
<value><string>wp.getPostStatusList</string></value>  
<value><string>wp.getCommentCount</string></value>  
<value><string>wp.deleteFile</string></value>  
<value><string>wp.uploadFile</string></value>  
<value><string>wp.suggestCategories</string></value>  
<value><string>wp.deleteCategory</string></value>  
<value><string>wp.newCategory</string></value>  
<value><string>wp.getTags</string></value>  
<value><string>wp.getCategories</string></value>  
<value><string>wp.getAuthors</string></value>  
<value><string>wp.getPageList</string></value>  
<value><string>wp.editPage</string></value>  
<value><string>wp.deletePage</string></value>  
<value><string>wp.newPage</string></value>  
<value><string>wp.getPages</string></value>  
<value><string>wp.getPage</string></value>  
<value><string>wp.editProfile</string></value>  
<value><string>wp.getProfile</string></value>  
<value><string>wp.getUsers</string></value>  
<value><string>wp.getUser</string></value>  
<value><string>wp.getTaxonomies</string></value>  
<value><string>wp.getTaxonomy</string></value>  
<value><string>wp.getTerms</string></value>  
<value><string>wp.getTerm</string></value>  
<value><string>wp.deleteTerm</string></value>  
<value><string>wp.editTerm</string></value>  
<value><string>wp.newTerm</string></value>  
<value><string>wp.getPosts</string></value>  
<value><string>wp.getPost</string></value>  
<value><string>wp.deletePost</string></value>  
<value><string>wp.editPost</string></value>  
<value><string>wp.newPost</string></value>  
<value><string>wp.getUsersBlogs</string></value>  
</data></array>  
</value>  
</param>  
</params>  
</methodResponse>
```

Fig. C3 XML-RPC system.listMethods response (part 2), full authenticated method set through wp.getUsersBlogs.

```

(kali@kali)-[~]
$ curl -s http://192.168.72.130/wordpress/xmlrpc.php -d '<?xml version="1.0"?><methodCall><methodName>wp.getUsersBlogs</methodName><params><param><value>michael</value></param><param><value>Michael12456</value></param></params></methodCall>'
<?xml version="1.0" encoding="UTF-8"?>
<methodResponse>
  <fault>
    <value>
      <struct>
        <member>
          <name>faultCode</name>
          <value><int>403</int></value>
        </member>
        <member>
          <name>faultString</name>
          <value><string>Incorrect username or password.</string></value>
        </member>
      </struct>
    </value>
  </fault>
</methodResponse>

```

Fig. C4 Controlled authentication attempt 001 (wp.getUsersBlogs, michael / Michael12456): fault 403, "Incorrect username or password."

```

(kali@kali)-[~]
$ chmod +x runner.sh
./runner.sh
Trying: raven123 at Sun Sep 13 05:37:58 AM EDT 2026
<string>Incorrect username or password.</string>
Trying: Raven2018 at Sun Sep 13 05:38:03 AM EDT 2026
<string>Incorrect username or password.</string>
Trying: security1 at Sun Sep 13 05:38:08 AM EDT 2026
<string>Incorrect username or password.</string>
(kali@kali)-[~]

```

Fig. C5 Controlled authentication attempts 002–004 (candidates raven123, Raven2018, security1) executed via a rate-limited script; all returned the same generic fault.

```

(kali@kali)-[~]
$ ssh michael@192.168.72.130
The authenticity of host '192.168.72.130 (192.168.72.130)' can't be established.
ED25519 key fingerprint is SHA256:vBKxJra340AKWuFf1Gc8N3KkutJRQEQtgQbj2XRXG7w.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.72.130' (ED25519) to the list of known hosts.

```

Fig. C6 SSH session establishment to 192.168.72.130 as michael.

```
(kali㉿kali)-[~]  
$ ssh michael@192.168.72.130  
The authenticity of host '192.168.72.130 (192.168.72.130)' can't be established.  
ED25519 key fingerprint is SHA256:vBKxJra340AKWuFf1Gc8N3KkutJRQEQTgQbj2XRXG7w.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? y  
Please type 'yes', 'no' or the fingerprint: yes  
Warning: Permanently added '192.168.72.130' (ED25519) to the list of known hosts.  
michael@192.168.72.130's password:  
Permission denied, please try again.  
michael@192.168.72.130's password:  
Connection closed by 192.168.72.130 port 22
```

Fig. C7 SSH authentication attempts against michael; connection terminated by the server after two consecutive failures.

```
(kali㉿kali)-[~]  
$ ssh michael@192.168.72.130  
michael@192.168.72.130's password:  
Permission denied, please try again.  
michael@192.168.72.130's password:  
Permission denied, please try again.  
michael@192.168.72.130's password: █
```

Fig. C8 SSH authentication attempts continued in a subsequent session (candidates 3 and 4); both denied.

Appendix C (cont.) Additional Avenues Reviewed and Ruled Out

```
(kali㉿kali)-[~]  
$ curl -s http://192.168.72.130/wordpress/?feed=rss2  
  
(kali㉿kali)-[~]  
$ curl -s http://192.168.72.130/wordpress/?feed=rss2  
  
(kali㉿kali)-[~]  
$
```

Fig. C9 Site RSS feed (?feed=rss2) returning empty content; no additional theme-specific leads found.

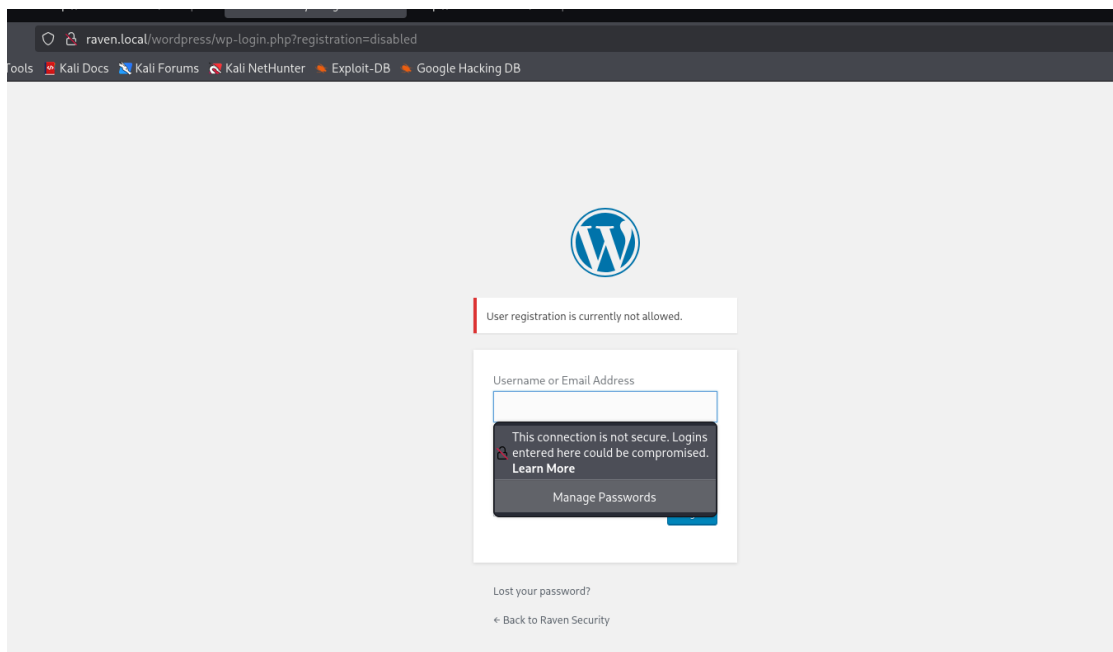


Fig. C10 Self-registration explicitly disabled ("User registration is currently not allowed"), ruling out account creation as an access path.

Appendix D File Hashes

File	Hash (SHA256)	Method
flag3.png	2479b9ab0c0763bf9bdc4c2fc36c701001a013a557a5a9f6beda44b024d9cc2e	sha256sum